BÀI TẬP NÂNG CAO — ĐẠI SỐ QUAN HỆ

Ứng dụng trong giám sát và kiểm soát truy cập

Mở đầu

Mọi hệ thống giám sát an ninh - hệ quản lý sự kiện an ninh (SIEM), hệ kiểm soát truy cập, công cụ điều tra số - đều quy về *truy vấn trên tập hợp bản ghi*. Khi viết một quy tắc phát hiện, thực chất ta đang viết một biểu thức đại số quan hệ. Nắm vững ngôn ngữ này cho phép:

- Phát biểu một **chính sách an ninh** dưới dạng chính xác, không nhập nhằng, theo khuôn mẫu *"tập các vi phạm phải rỗng"*.
- Nhận ra **giới hạn biểu diễn** của công cụ: có những câu hỏi an ninh - chẳng hạn "tồn tại chuỗi leo thang đặc quyền dài tùy ý hay không" - đã được *chứng minh* là không diễn đạt nổi bằng đại số quan hệ, và khi đó bắt buộc phải đổi công cụ.
- Hiểu bản chất của tấn công SQL injection: kẻ tấn công lợi dụng đúng những luật của đại số quan hệ được học ở đây, đặc biệt là điều kiện khả hợp của phép hợp.

Yêu cầu và quy tắc

Yêu cầu: đã nắm rõ định nghĩa hình thức của quan hệ, các loại khóa, ba ràng buộc toàn vẹn, và tám phép toán của đại số quan hệ truyền thống.

Ký hiệu	**Tên gọi**	**Ghi chú**
$\sigma_C(R)$	Chọn	giữ *hàng* thỏa điều kiện C; lược đồ không đổi
$\pi_L(R)$	Chiếu	giữ *cột* trong L, sau đó **khử bộ trùng**
$R \times S$	Tích Descartes	$\lvert R \times S\rvert = \lvert R\rvert \cdot \lvert S\rvert$
$R \bowtie S$	Kết tự nhiên	bằng nhau trên mọi thuộc tính trùng tên
$R \bowtie_\theta S$	Kết theta	$= \sigma_\theta(R \times S)$
$R \cup S$, $R \cap S$, $R - S$	Hợp, giao, hiệu	đòi hỏi hai quan hệ **khả hợp**
$\rho_{S(A_1,\ldots,A_n)}(R)$	Đổi tên	bắt buộc khi *tự kết*
$R \div S$	Chia	diễn đạt lượng từ "với mọi" — xem Phần 3
$\gamma_L(R)$	Gom nhóm, hàm gộp	phép *mở rộng*, không thuộc đại số quan hệ truyền thống

Quy tắc

1. Trừ khi đề nói rõ, chỉ được dùng **đại số quan hệ truyền thống** (σ, π, $\times$, $\bowtie$, $\cup$, $\cap$, $-$, ρ). Không dùng γ, không dùng hàm gộp, không viết SQL.

2. Mỗi biểu thức phải **có kiểu đúng**. Bài làm phải nêu rõ lược đồ của kết quả.

3. Với bài có phủ định ("chưa từng", "không", "chỉ"), phải chỉ ra *chỗ nào* dùng phép hiệu và *vì sao bắt buộc* phải dùng; cơ sở lý thuyết nằm ở Bài 21.

4. Bài đánh dấu $\star$ là bài thách thức; $\star\star$ đòi hỏi chứng minh chặt chẽ.

1 Lược đồ cơ sở dữ liệu "SOC"

Toàn bộ bài tập dùng chung lược đồ dưới đây, mô phỏng cơ sở dữ liệu của một Trung tâm Điều hành An ninh mạng (*Security Operations Center*). Mô hình kiểm soát truy cập được xây theo hướng **RBAC** (*Role-Based Access Control*).

Lược đồ quan hệ	**Ngữ nghĩa**
`NGUOIDUNG(MaND, TenDN, DonVi, TrangThai, NgayTao)`	Tài khoản. `TrangThai` $\in$ {`'HOATDONG'`, `'KHOA'`, `'HETHAN'`}; `TenDN` là khóa dự bị.
`VAITRO(MaVT, TenVT, MucNhayCam)`	Vai trò. `MucNhayCam` $\in \{1, \ldots, 5\}$, 5 là cao nhất.
`GAN(MaND, MaVT, NgayGan)`	Gán vai trò cho tài khoản (*user–role assignment*).
`PHANCAP(MaVT_Cha, MaVT_Con)`	Phân cấp vai trò: vai trò cha *thừa kế* mọi quyền của vai trò con.
`QUYEN(MaQ, TenQ, LoaiThaoTac)`	Quyền. `LoaiThaoTac` $\in$ {`'DOC'`, `'GHI'`, `'XOA'`, `'CAUHINH'`}.
`VT_QUYEN(MaVT, MaQ)`	Vai trò được cấp quyền nào (*role–permission assignment*).
`TAINGUYEN(MaTN, TenTN, PhanLoai, DonViSoHuu)`	Tài nguyên. `PhanLoai` $\in$ {`'CONGKHAI'`, `'NOIBO'`, `'MAT'`}.
`QUYEN_TN(MaQ, MaTN)`	Quyền áp dụng trên tài nguyên nào.
`PHIENDN(MaPhien, MaND, ThoiDiemBD, ThoiDiemKT, DiaChiIP, ThietBi)`	Phiên đăng nhập đã được xác thực thành công.
`NHATKY(MaNK, MaND, MaTN, ThaoTac, ThoiDiem, DiaChiIP, KetQua)`	Nhật ký kiểm toán. `KetQua` $\in$ {`'OK'`, `'TUCHOI'`}.

Giả thiết

Để các bài tập có lời giải xác định, quy ước:

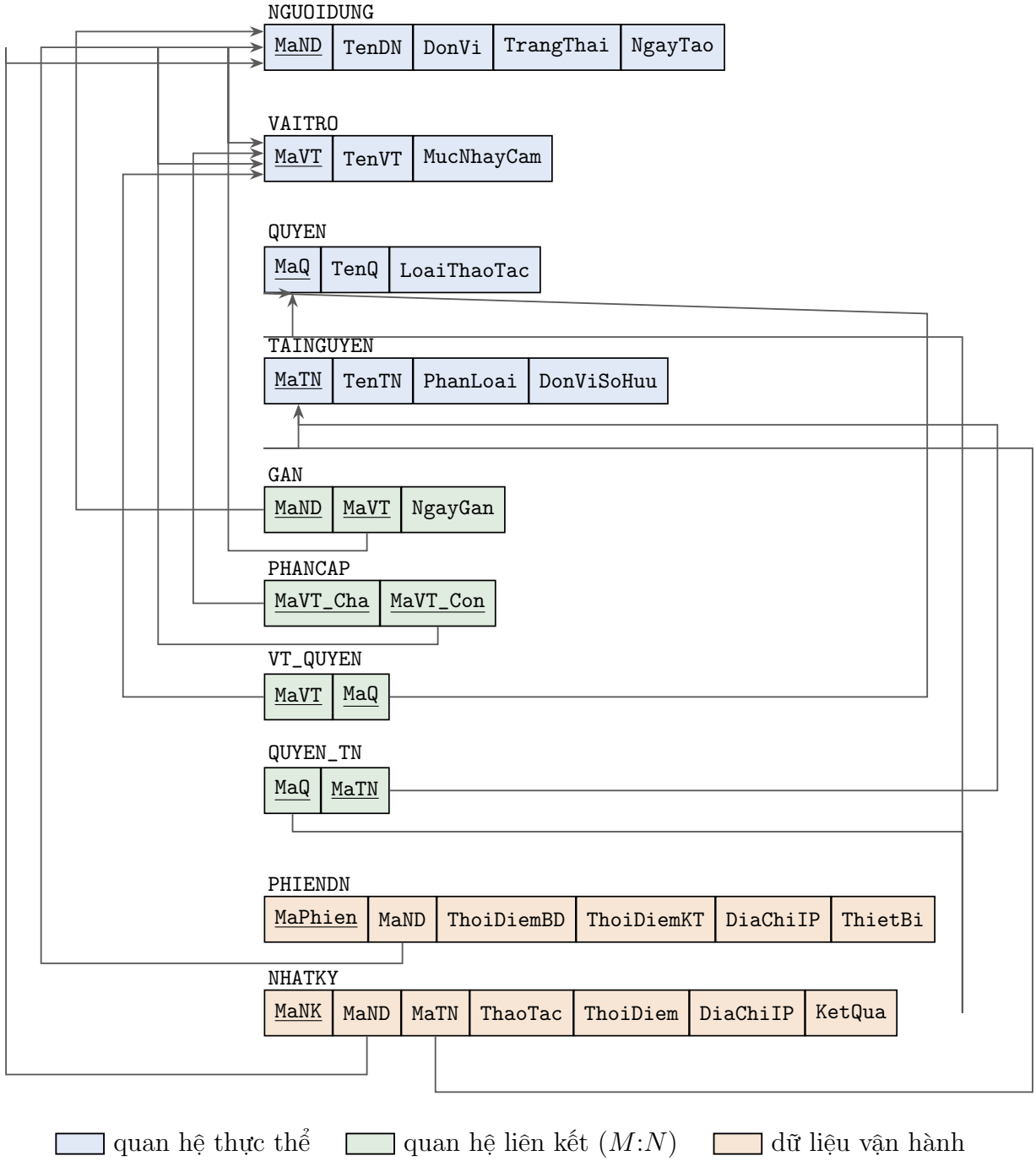
1. Mọi phiên trong `PHIENDN` đều đã kết thúc, tức `ThoiDiemKT` không nhận giá trị `NULL`. (Trường hợp phiên đang mở được bàn riêng ở Bài 7.)

2. `NGUOIDUNG.TrangThai` là trạng thái *hiện tại* của tài khoản, không phải trạng thái tại thời điểm phát sinh mỗi bản ghi nhật ký.

3. "Truy cập thành công" nghĩa là bản ghi nhật ký có `KetQua` = `'OK'`.

1.1 Sơ đồ tham chiếu

Sơ đồ dưới đây biểu diễn các **ràng buộc toàn vẹn tham chiếu** mỗi quan hệ là một dãy ô thuộc tính, thuộc tính khóa chính được gạch chân, và *mỗi mũi tên xuất phát từ thuộc tính khóa ngoại, trỏ tới thuộc tính khóa chính mà nó tham chiếu.*



quan hệ thực thể quan hệ liên kết (M:N) dữ liệu vận hành

- Thuộc tính **gạch chân** hợp thành khóa chính của quan hệ.
- Mỗi mũi tên là *một* ràng buộc toàn vẹn tham chiếu, đi từ khóa ngoại tới khóa chính được tham chiếu.
- Trong các quan hệ liên kết (`GAN`, `PHANCAP`, `VT_QUYEN`, `QUYEN_TN`), mọi thuộc tính *vừa* thuộc khóa chính *vừa* là khóa ngoại. Do ràng buộc toàn vẹn thực thể, chúng đều không được nhận giá trị `NULL`.

- `PHANCAP` tham chiếu `VAITRO` *hai lần* với hai vai trò khác nhau (cha và con) - đây là một liên kết **đệ quy**, và chính nó là tâm điểm của Bài 22.

1.2 Khái niệm "quyền hiệu dụng"

Định nghĩa 1 (Quyền hiệu dụng trực tiếp)**.** Người dùng u *có quyền hiệu dụng* q trên tài nguyên t nếu tồn tại vai trò v sao cho u được gán v, v được cấp q, và q áp dụng trên t.

$$\textsc{HieuDung} \;:=\; \pi_{MaND,\ MaQ,\ MaTN}\big(\mathrm{GAN} \bowtie \mathrm{VT_QUYEN} \bowtie \mathrm{QUYEN_TN}\big)$$

Phép kết thứ nhất thực hiện trên thuộc tính chung `MaVT`, phép kết thứ hai trên `MaQ`. Định nghĩa này **tạm bỏ qua** phân cấp vai trò; việc tính quyền có kể cả thừa kế qua `PHANCAP` là nội dung Bài 22.

2 Phần A - Truy vấn cơ bản

Bài 1. Liệt kê tên đăng nhập của các tài khoản đang bị khóa.

Bài 2. Liệt kê các địa chỉ IP đã từng có thao tác bị từ chối trên tài nguyên phân loại `'MAT'`.

Bài 3. Với mỗi người dùng, liệt kê tên các vai trò đã được gán. Kết quả có lược đồ `(TenDN, TenVT)`.

Bài 4. Liệt kê các tài khoản **chưa từng** có phiên đăng nhập nào. Nêu rõ vì sao biểu thức bắt buộc phải chứa phép hiệu.

Bài 5. Tìm các bản ghi nhật ký có địa chỉ IP *không* xuất hiện trong bất kỳ phiên đăng nhập nào của chính người dùng đó. Kết quả phải giữ nguyên lược đồ của `NHATKY`.

Đây là dấu hiệu kinh điển của việc bỏ qua cơ chế xác thực hoặc giả mạo nhật ký.

Bài 6. Tìm các cặp `(MaND, MaTN)` mà người dùng có quyền hiệu dụng, nhưng **chưa từng** truy cập thành công tài nguyên đó. Đây là đầu vào của bài toán rà soát đặc quyền dư thừa.

Bài 7. $\star$ **Phiên đồng thời từ hai địa chỉ khác nhau.** Tìm các người dùng có hai phiên đăng nhập *khác nhau*, có khoảng thời gian **giao nhau**, nhưng đến từ *hai* địa chỉ IP khác nhau.

Hai khoảng $[b_1, k_1]$ và $[b_2, k_2]$ giao nhau khi và chỉ khi $b_1 \le k_2 \wedge b_2 \le k_1$. Hãy giải thích thêm: nếu bỏ giả thiết "mọi phiên đều đã kết thúc" thì biểu thức phải sửa thế nào, và vì sao điều kiện so sánh với `NULL` lại không cho kết quả như mong đợi.

Bài 8. Tìm các người dùng được gán ít nhất *hai* vai trò khác nhau có `MucNhayCam` ≥ 4.

3 Phần B - Phép chia và các truy vấn "tất cả"

Định nghĩa 2 (Phép chia)**.** Cho $R(A, B)$ và $S(B)$, trong đó A và B là các *tập* thuộc tính rời nhau. Khi đó

$$R \div S \;=\; \{\, t \text{ trên } A \;\mid\; \forall s \in S,\ (t, s) \in R \,\}$$

Nói cách khác, $R \div S$ gồm các giá trị của A *ghép được với mọi* giá trị trong S. Đây là phép toán diễn đạt lượng từ "với mọi" trong đại số quan hệ.

Bài 9. ⋆⋆ Chứng minh rằng phép chia *không phải* phép toán cơ sở, bằng cách chứng minh đẳng thức sau và giải thích ý nghĩa của từng thành phần:

$$R \div S \;=\; \pi_A(R) \;-\; \pi_A\Big(\big(\pi_A(R) \times S\big) - R\Big)$$

Gợi ý: đọc vế phải theo hướng loại trừ. Tích $\pi_A(R) \times S$ là tập *mọi* cặp lẽ ra phải có; trừ đi R cho ra các cặp *còn thiếu*; chiếu xuống A cho ra các giá trị của A bị thiếu ít nhất một mảnh ghép.

Bài 10. Tìm các người dùng có quyền hiệu dụng trên **tất cả** tài nguyên phân loại `'MAT'`. Viết lời giải theo hai cách: dùng $\div$, và chỉ dùng các phép cơ sở.

Bài 11. Tìm các vai trò mà **mọi** quyền được cấp cho nó đều có `LoaiThaoTac = 'DOC'`.

Câu hỏi kèm theo: vai trò *không được cấp quyền nào* có thỏa mãn điều kiện trên hay không? Hãy nêu rõ quyết định của mình và lập luận. Đây là tình huống *chân lý rỗng* (*vacuous truth*), và hai cách trả lời dẫn tới hai biểu thức khác nhau.

Bài 12. ⋆ Tìm các người dùng **chỉ** truy cập hệ thống từ *đúng một* địa chỉ IP duy nhất. Gợi ý: "đúng một" = "có ít nhất một" trừ đi "có ít nhất hai".

Bài 13. ⋆ Tìm các tài nguyên **chỉ** bị truy cập bởi người dùng thuộc đúng đơn vị sở hữu tài nguyên đó. Tài nguyên không bị ai truy cập cũng được tính là thỏa mãn.

Bài 14. ⋆⋆ Tìm các cặp người dùng (u_1, u_2) với $u_1 \neq u_2$ có **cùng một tập quyền hiệu dụng**.

Gợi ý: $X = Y \iff X \subseteq Y \wedge Y \subseteq X$, và $X \subseteq Y \iff X - Y = \emptyset$. Hãy diễn đạt mệnh đề "không tồn tại quyền mà u_1 có còn u_2 không có" bằng đại số quan hệ.

4 Phần C - Chính sách an ninh thành ràng buộc

Với mọi bài trong phần này, hãy viết một biểu thức V mô tả **tập các tình huống vi phạm**, rồi phát biểu chính sách dưới dạng $V = \emptyset$ hoặc $R \subseteq S$.

Logic cần nhớ: chính sách dạng "*nếu P thì Q*" có tập vi phạm là $\sigma_{P \wedge \neg Q}(\cdots)$. Mô tả tình huống vi phạm bao giờ cũng dễ hơn mô tả trực tiếp "điều đúng", và quan trọng hơn: biểu thức vi phạm có thể đem chạy để *liệt kê* các bản ghi sai, còn mệnh đề "điều đúng" thì không.

Bài 15. Phân tách nhiệm vụ (Separation of Duty). Không tài khoản nào được đồng thời giữ vai trò có `TenVT = 'QuanTriHeThong'` và vai trò `'KiemToanVien'`.

Bài 16. Đặc quyền tối thiểu. Không tài khoản có `TrangThai = 'KHOA'` nào được có quyền hiệu dụng với `LoaiThaoTac = 'CAUHINH'`.

Bài 17. Khóa tài khoản có hiệu lực. Không tồn tại phiên đăng nhập của một tài khoản đang ở trạng thái `'KHOA'`.

Hãy nêu rõ: lược đồ hiện tại *chưa đủ* để kiểm tra chính xác ràng buộc này. Vì sao? Cần bổ sung gì vào lược đồ, và giả thiết nào trong mục "Giả thiết chung" đang bị chính bài này thách thức?

Bài 18. Bắt buộc ghi nhật ký. Mọi thao tác trên tài nguyên phân loại `'MAT'` đều phải để lại bản ghi nhật ký. Viết ràng buộc dưới dạng $\subseteq$ và giải thích vì sao nó *không thể* được cưỡng chế chỉ bằng khóa ngoại.

Bài 19. ⋆ **Bức tường Trung Hoa (Chinese Wall).** Giả sử bổ sung quan hệ liệt kê các cặp đơn vị xung đột lợi ích:

`CANHTRANH(DonViA, DonViB)`

Chính sách: không người dùng nào được truy cập, dù chỉ một lần, tài nguyên của *cả hai* đơn vị trong cùng một cặp cạnh tranh.

Lưu ý khi làm bài: quan hệ `CANHTRANH` có đối xứng hay không? Điều đó ảnh hưởng thế nào tới biểu thức của em?

Bài 20. ⋆ Toàn vẹn của nhật ký. Lược đồ khai báo `NHATKY.MaND` là khóa ngoại trỏ tới `NGUOIDUNG`. Một quản trị viên đề xuất khai báo `ON DELETE CASCADE` cho "gọn".

(a) Viết ràng buộc toàn vẹn tham chiếu hiện tại dưới dạng biểu thức đại số quan hệ.

(b) Giải thích vì sao `CASCADE` ở đây là một lỗ hổng an ninh nghiêm trọng, và đề xuất thiết kế thay thế bảo toàn được khả năng kiểm toán.

5 Phần D - Lý thuyết và giới hạn biểu diễn

Bài 21. ⋆⋆ Tính đơn điệu. Một truy vấn Q gọi là *đơn điệu* nếu với mọi cặp thể hiện $r \subseteq r'$ ta luôn có $Q(r) \subseteq Q(r')$.

(a) Chứng minh rằng σ, π, $\times$, $\bowtie$ và $\cup$ đều **bảo toàn** tính đơn điệu: nếu các toán hạng là truy vấn đơn điệu thì kết quả cũng đơn điệu.

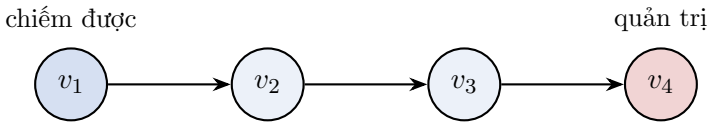
(b) Chứng minh rằng phép hiệu $-$ **không** đơn điệu theo toán hạng thứ hai, bằng một phản ví dụ cụ thể.

(c) Từ (a) và (b), chứng minh chặt chẽ rằng truy vấn "*các tài khoản chưa từng đăng nhập*" (Bài 4) **không thể** viết được nếu không dùng phép hiệu.

(d) Liên hệ an ninh: vì sao kết luận này có nghĩa là mọi quy tắc phát hiện dựa trên *sự vắng mặt* của một sự kiện - thiếu bản ghi nhật ký, thiếu lần đăng xuất — đều tốn kém hơn hẳn các quy tắc dựa trên *sự có mặt*?

Bài 22. ⋆⋆ Chuỗi leo thang đặc quyền và bao đóng bắc cầu.

Quan hệ `PHANCAP(MaVT_Cha, MaVT_Con)` cho biết vai trò cha thừa kế mọi quyền của vai trò con. Kẻ tấn công chiếm được một vai trò và muốn biết nó vươn tới được những vai trò nào qua một chuỗi thừa kế *dài tùy ý*.



chuỗi dài 3 — nhưng trong thực tế độ dài không bị chặn trước

(a) Viết biểu thức đại số quan hệ cho tập các cặp vai trò nối nhau qua chuỗi dài *đúng* 2, rồi *đúng* 3.

(b) Viết biểu thức cho tập các cặp nối nhau qua chuỗi dài **không quá** k, với k là hằng số cho trước.

(c) Giải thích vì sao cách làm ở (b) **không** tổng quát hóa được cho k tùy ý. Nêu định lý tương ứng.

(d) Viết truy vấn giải quyết bài toán bằng `WITH RECURSIVE` của SQL và chỉ rõ *khả năng diễn đạt nào* đã được bổ sung so với đại số quan hệ.

Kiến thức nền cho Bài 22

Định lý 1 (Aho và Ullman, 1979)**.** *Bao đóng bắc cầu của một quan hệ nhị phân không biểu diễn được bằng bất kỳ biểu thức đại số quan hệ nào.*

Ý tưởng chứng minh: mỗi biểu thức đại số quan hệ là một công thức có *độ dài cố định*, nên chỉ "nhìn xa" được một số bước hữu hạn do chính độ dài đó quyết định. Với mọi biểu thức cho trước, luôn dựng được một đồ thị đường thẳng đủ dài để biểu thức bỏ sót cặp hai đầu.

Đây chính là lý do chuẩn SQL:1999 phải bổ sung `WITH RECURSIVE`, và cũng là lý do các công cụ phân tích đường tấn công (*attack path*) thường chuyển sang cơ sở dữ liệu đồ thị thay vì cơ sở dữ liệu quan hệ thuần túy.

Bài 23. ⋆ Tính đầy đủ quan hệ và tính an toàn.

(a) Phát biểu định lý Codd về quan hệ giữa đại số quan hệ và phép tính quan hệ, nêu rõ điều kiện *an toàn* xuất hiện ở đâu trong phát biểu đó.

(b) Biểu thức phép tính quan hệ

$$\{\, t \mid \neg\, \mathrm{NGUOIDUNG}(t) \,\}$$

("mọi bộ *không* thuộc `NGUOIDUNG`") được gọi là *không an toàn*. Giải thích vì sao, và vì sao đại số quan hệ không bao giờ gặp vấn đề này.

(c) Liên hệ an ninh: vì sao tính an toàn là một bảo đảm quan trọng đối với hệ thống phải chống tấn công từ chối dịch vụ ở tầng truy vấn?

Bài 24. ⋆ SQL injection nhìn từ đại số quan hệ.

Một ứng dụng xây câu truy vấn bằng cách nối chuỗi:

```
SELECT TenTN, PhanLoai FROM TAINGUYEN WHERE MaTN = '<input>'
```

Kẻ tấn công nhập vào ô `<input>` chuỗi sau:

```
' UNION SELECT TenDN, TrangThai FROM NGUOIDUNG --
```

(a) Viết biểu thức đại số quan hệ mô tả kết quả mà máy chủ thực sự trả về.

(b) Dựa vào **điều kiện khả hợp** của phép hợp, giải thích vì sao kẻ tấn công bắt buộc phải dò đúng số cột trước, và vì sao hắn thường thử lần lượt `ORDER BY 1`, `ORDER BY 2`, … để làm việc đó.

(c) Vì sao truy vấn tham số hóa triệt tiêu được tấn công này, trong khi lọc ký tự nháy đơn thì không? Trả lời bằng lập luận "mã lệnh và dữ liệu", không bằng danh sách mẹo.

Bài 25. ⋆⋆ Tấn công suy diễn qua khung nhìn. Người quản trị tạo một khung nhìn được cho là "đã ẩn danh":

$$\mathrm{V} \;:=\; \pi_{\mathit{DonVi},\ \mathit{PhanLoai},\ \mathit{ThoiDiem}}\big(\mathrm{NHATKY} \bowtie \mathrm{NGUOIDUNG} \bowtie \mathrm{TAINGUYEN}\big)$$

và cấp cho một nhóm phân tích viên chỉ quyền đọc trên V, không cấp quyền trên các bảng gốc.

(a) Giả sử một đơn vị chỉ có *đúng một* tài khoản. Chứng tỏ rằng phân tích viên vẫn khôi phục được hành vi của cá nhân đó. Đây gọi là *tấn công suy diễn* (*inference attack*).

(b) Tổng quát hóa: phát biểu điều kiện trên dữ liệu để phép chiếu $\pi_{DonVi,\ldots}$ thực sự ẩn danh được. Liên hệ với khái niệm k-ẩn danh (k-anonymity).

(c) Đề xuất một ràng buộc dạng "tập vi phạm phải rỗng" mà hệ thống có thể kiểm tra *trước khi* công bố khung nhìn.

6 Phụ lục - Hướng dẫn nộp bài và đánh giá

Tiêu chí	Điểm	Ghi chú
Phần A - truy vấn cơ bản	2,0	Đúng kiểu, đúng ngữ nghĩa
Phần B - phép chia, truy vấn "tất cả"	2,5	Có cả dạng $\div$ và dạng cơ sở
Phần C - chính sách thành ràng buộc	2,5	Phát biểu đúng *tập vi phạm*
Phần D - lý thuyết	2,0	Chứng minh phải chặt chẽ
Chất lượng trình bày và lập luận	1,0	Nêu rõ lược đồ kết quả mỗi biểu thức

Những lỗi bị trừ điểm nặng

- Dùng γ hoặc hàm gộp ở những bài yêu cầu đại số quan hệ truyền thống.
- Tự kết mà không đổi tên bằng ρ - biểu thức khi đó vô nghĩa.
- Quên điều kiện loại cặp "một bộ ghép với chính nó" trong các bài tự kết.
- Khi mô tả "giá trị không hợp lệ", viết $\sigma_{A\neq x \vee A\neq y}$ thay cho $\sigma_{A\neq x \wedge A\neq y}$: với phép tuyển, mọi bộ đều thỏa mãn nên biểu thức luôn khác rỗng và ràng buộc trở thành vô nghĩa.
- Dùng π rồi quên rằng nó **khử bộ trùng**, dẫn tới kết luận sai về số lượng.
- Ở Phần C: mô tả "điều đúng" thay vì "tập vi phạm". Hai cách không tương đương về khả năng kiểm tra và truy vết.

Tài liệu đọc thêm

- H. Garcia-Molina, J. D. Ullman, J. Widom. *Database Systems: The Complete Book*, 2nd ed., Pearson, 2008 — Chương 2 và 5.
- R. Elmasri, S. B. Navathe. *Fundamentals of Database Systems*, 7th ed., Pearson, 2016 — Chương 5 (ràng buộc toàn vẹn, sơ đồ tham chiếu) và Chương 8 (đại số quan hệ).
- S. Abiteboul, R. Hull, V. Vianu. *Foundations of Databases*, Addison-Wesley, 1995 — Phần D: truy vấn đệ quy (Datalog) và giới hạn biểu diễn của các ngôn ngữ truy vấn.
- A. V. Aho, J. D. Ullman. *Universality of Data Retrieval Languages*. POPL 1979 — bài báo gốc của định lý nêu ở Bài 22.
- R. Sandhu, E. Coyne, H. Feinstein, C. Youman. *Role-Based Access Control Models*. IEEE Computer, 29(2), 1996 — mô hình RBAC mà lược đồ SOC mô phỏng.
- OWASP. *SQL Injection Prevention Cheat Sheet*.